Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
☐	☑	Least Privilege
☐	☑	Disaster recovery plans
☑	☐	Password policies
☐	☑	Separation of duties
☑	☐	Firewall
☐	☑	Intrusion detection system (IDS)
☐	☑	Backups
☑	☐	Antivirus software
☑	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☑	Encryption
☐	☑	Password management system
☑	☐	Locks (offices, storefront, warehouse)
☑	☐	Closed-circuit television (CCTV) surveillance
☑	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☑	Only authorized users have access to customers' credit card information.
☐	☑	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☑	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☑	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☑	E.U. customers' data is kept private/secured.
☑	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☑	Ensure data is properly classified and inventoried.
☑	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☑	User access policies are established.
☐	☑	Sensitive data (PII/SPII) is confidential/private.

- [x] [ ] Data integrity ensures the data is consistent, complete, accurate, and has been validated.
- [x] [ ] Data is available to individuals authorized to access it.

The risk assessment assigns Botium Toys a score of **8/10**. The report rates the potential impact of asset loss as medium because the IT department does not know which assets would be at risk. It also rates the risk of asset-related consequences or regulatory fines as high.

I recommend prioritizing the following corrective actions.

Priority	Finding	Recommended corrective action	Why it matters
Critical	Excessive employee access	Implement least privilege and role-based access restrictions.	Reduces the risk of unauthorized access to sensitive information.
Critical	Unprotected cardholder information	Implement appropriate encryption and review payment-data security.	Helps protect sensitive payment information.
Critical	No backups or disaster recovery plan	Establish regular backups and a tested disaster recovery plan.	Helps recover critical systems and data after an incident.
High	No intrusion detection system	Evaluate and implement an IDS appropriate to the organization's needs.	Improves the ability to detect suspicious network activity.
High	Weak password requirements	Strengthen the password policy and introduce centralized password management.	Reduces account-compromise risk and password-reset problems.
High	Inadequate asset management	Inventory and classify hardware, software, systems, and sensitive data.	Helps identify critical assets and prioritize protection.

High	No separation of duties	Separate sensitive responsibilities and establish appropriate approval procedures.	Reduces the risk of misuse of privileges and malicious insider activity.
Medium	Unstructured legacy-system maintenance	Establish a maintenance schedule and document monitoring and intervention procedures.	Helps ensure outdated systems receive consistent attention.
Medium	Compliance gaps	Review relevant PCI DSS and GDPR requirements and document evidence of implemented safeguards.	Helps identify remaining compliance obligations and demonstrate control effectiveness.

These priorities are my recommendations based on the identified risks. The source report specifically calls for asset identification, classification, and assessment of the impact of asset loss on business continuity.

Recommended implementation order

First: Protect sensitive information.

- Restrict employee access to customer data.
- Implement least privilege.
- Protect cardholder data using appropriate security measures.
- Strengthen password practices.

Second: Improve recovery and detection.

- Create and test a disaster recovery plan.
- Establish reliable backups of critical data.
- Evaluate intrusion detection capabilities.

Third: Improve management and compliance.

- Complete the asset inventory.
- Establish a legacy-system maintenance schedule.
- Review applicable compliance requirements.
- Document control ownership and evidence.

This sequence prioritizes direct data-protection weaknesses and the absence of recovery capabilities before broader process improvements.

Conclusion

Botium Toys has several foundational safeguards, including a firewall, antivirus software, physical locks, CCTV, and fire protection. However, these controls do not compensate for the lack of appropriate access restrictions, encryption, backups, disaster recovery planning, and intrusion detection.

The most urgent recommendation is to protect sensitive data and restrict access, followed by establishing reliable recovery capabilities and improving detection. Asset inventory, documented procedures, and compliance reviews should support these improvements.

One final qualification: the documents support a preliminary risk assessment, but they do not establish that Botium Toys is formally compliant or noncompliant with every requirement of PCI DSS, GDPR, or SOC. Formal conclusions would require examining the applicable requirements and collecting additional evidence.

You can use the Yes/No tables above to complete your controls and compliance checklist, then use the recommendations section to summarize the corrective actions for the IT manager.